À la croisée des Arts

Projet commun MSc DPO × Data/IA 2026 : RGPD, AI Act et IA générative

Introduction du sujet

Note d'accompagnement pédagogique

Ce projet réunit les étudiants du MSc DPO et du MSc Data/IA autour d'un même produit : une application d'IA générative qui traite des données personnelles, prend des décisions automatisées et doit être mise en conformité avec le RGPD et l'AI Act.

Les groupes sont obligatoirement hybrides : 1 ou 2 étudiants DPO et 1 ou 2 étudiants Data/IA. Chaque étudiant est évalué selon la grille de compétences de sa propre formation, mais le groupe porte une présentation et un dossier communs.

Le contexte réglementaire en 2026

Le RGPD encadre le traitement des données personnelles depuis 2018 : base légale, minimisation, limitation de la conservation, sécurité, droits des personnes, encadrement des décisions individuelles automatisées. Il n'a pas été remplacé par l'AI Act : les deux textes s'appliquent en même temps, et un même traitement peut relever des deux.

L'AI Act (règlement (UE) 2024/1689, ou RIA) classe les systèmes d'IA selon leur niveau de risque et s'applique par étapes :

Échéance	Ce qui s'applique
2 février 2025	Pratiques d'IA interdites (article 5) et obligation de maîtrise de l'IA (article 4).
2 août 2025	Obligations des fournisseurs de modèles d'IA à usage général (GPAI), gouvernance et sanctions.

Échéance	Ce qui s'applique
2 août 2026	Obligations de transparence (article 50) : informer les personnes qu'elles interagissent avec une IA, marquer les contenus générés, informer en cas de catégorisation biométrique ou de reconnaissance des émotions.
2 décembre 2027	Obligations des systèmes à haut risque de l'annexe III (date reportée par le règlement « Digital Omnibus » (UE) 2026/1744, entré en vigueur le 27 juillet 2026).
2 août 2028	Systèmes à haut risque intégrés à des produits déjà réglementés (annexe I).

Ce calendrier est votre point de départ, pas votre point d'arrivée : **vérifier, compléter et sourcer ces dates fait partie du travail de veille demandé** (aménagements transitoires, nouvelles interdictions introduites par l'Omnibus, lignes directrices et codes de pratique publiés par la Commission et la CNIL).

Sujet

Arbitrer, encadrer et reconcevoir une IA générative de recommandation de mode pour la rendre conforme au RGPD et à l'AI Act, aujourd'hui et à l'horizon 2027.

Les groupes doivent :

- qualifier chaque fonctionnalité du produit au regard du RGPD et de l'AI Act, et décider pour chacune : **garder, encadrer ou retirer** ;
- proposer des mesures techniques et organisationnelles ancrées dans des bonnes pratiques reconnues (privacy by design et by default, normes ISO 27701 et ISO 42001, sécurité applicative), et non une accumulation de correctifs ;
- concevoir la V2 du produit : architecture, cahier des charges, feuille de route de conformité 2026-2027 ;
- démontrer, sur un périmètre limité, qu'un traitement de données conforme peut être réellement implémenté (preuve de concept Data/IA).

Mise en situation professionnelle

Contexte

Vous rejoignez **FashMatch**, une start-up marseillaise de la fashion tech qui vient de lever des fonds auprès d'investisseurs européens. Son application mobile et web propose à chaque client des vêtements et accessoires adaptés à son style, et lui permet de les « essayer » virtuellement avant d'acheter. La version **FashMatch V1** est en accès anticipé depuis six mois auprès de plusieurs milliers d'utilisateurs. Les modèles ont été ajustés sur les données de ces premiers clients. L'équipe technique est composée de six personnes ; il n'y a ni DPO désigné, ni référent conformité IA.

Les modules de FashMatch V1

Le prototype livré par l'équipe technique se compose de six modules :

Module	Ce qu'il fait aujourd'hui
Match Recommandation	Recommande des produits du catalogue à partir de l'historique de navigation et d'achats, des préférences déclarées à l'inscription et des tendances du moment. Les données sont conservées 5 ans par défaut.
Cabine Essayage virtuel	À partir d'un selfie ou d'une photo en pied, un modèle génératif produit une image réaliste de l'utilisateur portant la tenue choisie. Les images sont téléchargeables et partageables sur les réseaux sociaux, sans mention particulière. N'importe quelle photo peut être importée.
Stella Styliste conversationnel	Un assistant conversationnel, construit sur l'API d'un fournisseur de modèle d'IA à usage général, conseille l'utilisateur, répond à ses questions et pousse des produits. Il se présente sous un prénom et un avatar humain. Les conversations sont conservées pour améliorer le service.
Âge Contrôle à l'inscription	L'accès est réservé aux personnes de 15 ans et plus. L'âge est estimé automatiquement à partir d'une photo du visage ; si l'estimation est inférieure à 15 ans, l'inscription est refusée, sans explication ni recours, quel que soit l'âge déclaré.
Pay3x Paiement fractionné	Paiement en 3 ou 4 fois. L'éligibilité est décidée automatiquement par un score calculé à partir de l'historique d'achats, des incidents de paiement et de données transmises par le prestataire de paiement. Un refus est affiché sans motif.
Insight Segmentation marketing	Analyse les photos importées pour déduire des caractéristiques des utilisateurs (signes religieux portés, orientation sexuelle supposée, origine) afin de créer des segments marketing et des campagnes ciblées.

Sur le plan technique : l'application est hébergée chez un fournisseur cloud dont certains services sont opérés hors de l'Union européenne ; les photos sont stockées en clair dans un bucket objet ; les accès internes ne sont pas journalisés ; aucun audit d'accessibilité n'a été mené sur l'application.

Les exigences de la direction

La direction ne veut pas d'un produit vidé de sa substance. Elle tient à trois promesses : une recommandation vraiment personnalisée, l'essayage virtuel qui fait la différence face aux concurrents, et un parcours d'achat fluide jusqu'au paiement. Elle accepte de retirer ou de transformer une fonctionnalité **si on lui explique pourquoi, et ce qu'on propose à la place**.

La crise

En une semaine, trois événements s'enchaînent :

- un journaliste spécialisé demande à FashMatch comment sont utilisées les photos des clients, et si elles ont servi à entraîner les modèles ;
- un parent signale que sa fille de 14 ans a pu créer un compte avec une photo retouchée, puis a utilisé le paiement fractionné ;
- une femme découvre qu'une image d'elle en maillot de bain, générée par Cabine à partir d'une photo publiée sur son compte Instagram, circule sur un forum. Elle n'a jamais été cliente de FashMatch.

La direction générale vous convoque :

« Nous avons affirmé partout que nous étions conformes au RGPD et à l'AI Act. Les investisseurs veulent des preuves, la presse veut des réponses. Dites-nous ce qu'on garde, ce qu'on encadre et ce qu'on arrête, et montrez-nous à quoi ressemble une V2 qui tient la route en 2026 comme en 2027. »

Vos responsables DPO et Data/IA vous demandent de travailler en groupe hybride pour produire le dossier ci-dessous.

Livrables attendus

En commun

- **L0 Planning du groupe** : répartition des rôles, jalons internes, dates de remise de chaque livrable. Le planning est un livrable évalué.
- **L1 Matrice de tri des modules** : pour chaque module, qualification RGPD et AI Act, décision (garder, encadrer, retirer), justification juridique et technique. Ce document est co-construit par les DPO et les Data/IA.
- **L2 Présentation projet DPO-IA** : support de soutenance destiné au CEO et au CTO de FashMatch.

Côté DPO

- **L3 Note de veille réglementaire** à l'oral lors de la présentation par les DPO aux IA Act Jeudi : textes applicables à FashMatch, calendrier d'application 2025-2028, sources évaluées selon leur fiabilité.
- **L4 Registre des activités de traitement** (article 30 du RGPD).
- **L5 Inventaire des systèmes d'IA** de FashMatch, avec leur qualification au sens de l'AI Act et le rôle de FashMatch (fournisseur, déployeur).

Côté Data/IA

- **L6 Analyse de risques data/IA** : risques sur tout le cycle de vie (données, entraînement, modèle, déploiement, usage, sécurité), pas uniquement réglementaires, avec mesures de mitigation et risque résiduel. (a mettre en commun pas que pour l'ia faut le deplacer)
- **L7 Cahier des charges de FashMatch V2**, comprenant : un schéma d'architecture conforme ; les spécifications fonctionnelles et techniques ; une section sécurité documentant les mécanismes appliqués (chiffrement, gestion des accès, journalisation) ; une section accessibilité pour les personnes en situation de handicap ; une matrice de traçabilité exigence → mesure → article de loi ou norme ; la feuille de route de conformité 2026-2027.(je veux voir un avant apres schéma de pipeline ou de cycle de vie de la donnée)

- **POC Pipeline de données conforme** : voir ci-dessous.

La preuve de concept Data/IA

L'application FashMatch V2 n'est pas à développer. En revanche, l'équipe Data/IA démontre sur un périmètre limité qu'un traitement conforme est implémentable. Le POC est un **pipeline de données** qui :

- extrait et charge un catalogue produits public (par exemple un dataset de vêtements et accessoires de Kaggle) et un jeu de **profils utilisateurs synthétiques** générés par le groupe, avec un outil d'IA générative ou une bibliothèque de génération ; **aucune donnée réelle, aucune photo de personne réelle** ;
- applique les mesures préconisées dans le cahier des charges : minimisation des champs, pseudonymisation, durées de conservation et purge automatique, journalisation des traitements ;
- évalue la qualité et la pertinence des données (complétude, doublons, cohérence, déséquilibres pouvant créer des biais) et produit un rapport de qualité lisible par un tiers qui est versionné, documenté et exécutable par un tiers (README, dépendances, conteneur ou environnement reproductible).

Le POC est volontairement modeste : il ne doit pas consommer le temps du cadrage, ni désynchroniser l'équipe DPO.

Calendrier des remises

Les dates exactes sont communiquées au lancement du projet. Les livrables sont remis dans le dépôt du groupe aux échéances déterminées par les groupes au plus tard le Mardi soir.

Des **consultations techniques communes** ont lieu chaque semaine avec les équipes pédagogiques des deux formations. Elles vérifient l'avancement par rapport au planning (L0) et débloquent les questions croisées. Les séances de travail ne sont pas toutes communes : chaque filière dispose aussi de temps propre.

Comment produire les documents de l'équipe Data/IA

L'analyse de risques (L7) prend la forme d'un registre. Chaque risque a un identifiant, le module concerné, une description, sa source (données, modèle, infrastructure, usage, humain), une probabilité, un impact, la mesure de mitigation, le risque résiduel et un responsable. Pensez aux risques propres à l'IA : biais, dérive, hallucination, injection de prompt, fuite de données d'entraînement, détournement de l'essayage virtuel.

Le cahier des charges (L8) suit une structure classique : contexte et objectifs, périmètre, acteurs et parcours utilisateurs, exigences fonctionnelles, exigences non fonctionnelles (sécurité, accessibilité, performance, conformité), architecture, contraintes, feuille de route. Chaque exigence de conformité est rattachée à une source (article du RGPD ou de l'AI Act, norme, recommandation de la CNIL).

Le schéma d'architecture montre les flux de données de bout en bout : collecte, stockage, traitements, modèles, sous-traitants et fournisseurs tiers, zones de confiance, localisation des données, points de journalisation et de supervision humaine.

Évitez le « Frankenstein » : une mesure de conformité ajoutée en fin de chaîne pour boucher un trou est une dette. Privilégiez les choix d'architecture qui rendent la conformité structurelle (séparation des données sensibles, minimisation dès la collecte, supervision humaine intégrée au parcours, transparence par conception).

Compétences visées

Compétences du groupe DPO

Code bloc RNCP	Titre de la compétence
RNCP40652BC01	Définir les besoins de l'entreprise en termes de sécurité et de conformité
RNCP40652BC02	Implémenter une politique de sécurité et de conformité des données personnelles

Code bloc RNCP	Titre de la compétence
RNCP40652BC03	Gérer un incident de sécurité et/ou de conformité de protection des données personnelles
RNCP40652BC04	Accompagner les utilisateurs aux règles relatives à la protection des données personnelles

Compétences transversales : gestion de projet et travail d'équipe.

Compétences du groupe Data/IA

Code bloc RNCP	Titre de la compétence	Mobilisé dans ce projet par
RNCP40573BC01	Définir une stratégie de systèmes d'information	L1 – Note de veille : orientations réglementaires (IA Act), sources évaluées selon les normes et leur fiabilité
RNCP40573BC02	Piloter des projets informatiques	L0 – Planning ; L8 – Cahier des charges technique respectant le RGPD et intégrant l'accessibilité aux personnes en situation de handicap
RNCP40573BC03	Concevoir et développer une application informatique	L8 – Architecture et section sécurité : mécanismes de protection documentés (RGPD, chiffrement, gestion des accès)
RNCP40573BC05	Construire et implémenter des modèles de big data et d'IA	POC – Pipeline : extraction, transformation, chargement, évaluation de la qualité des données, application du RGPD

Compétences transversales : évaluation des implications éthiques de l'IA ; gestion de projet et travail d'équipe.

Rendu

Chaque groupe dispose d'**un seul dépôt GitHub**, qui fait foi pour l'ensemble des livrables : github.com/prenom-nom/croisee-des-arts-2026 (dépôt porté par un membre du groupe, les autres en collaborateurs, l'équipe pédagogique invitée).

Organisation attendue du dépôt :

- /commun : L0, L1, L2 et la présentation L9 ;

- /dpo : L3, L4, L5, L6 (exports PDF ; les documents de travail peuvent rester sur Google Docs) ;
- /data-ia : L7, L8 et le schéma d'architecture ;
- /poc : le code du pipeline, son README et le rapport de qualité des données.

Les étudiants DPO transmettent également leurs documents à l'adresse Msc-DPO-ResponsablesPedagogiques@laplateforme.io.

Le projet fait l'objet d'une **soutenance de 15 minutes**

Textes officiels

- Règlement (UE) 2024/1689 sur l'intelligence artificielle (AI Act) : https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32024R1689
- Règlement (UE) 2016/679, RGPD : https://eur-lex.europa.eu/eli/reg/2016/679/oj
- Règlement « Digital Omnibus » sur l'IA (UE) 2026/1744 : à retrouver sur EUR-Lex dans le cadre de la veille

Ressources de référence

- AI Act, version navigable en français : https://artificialintelligenceact.eu/fr/
- EU AI Act Compliance Checker : https://artificialintelligenceact.eu/assessment/eu-ai-act-compliance-checker/
- CNIL, questions-réponses sur l'entrée en vigueur du règlement IA : https://www.cnil.fr/fr/entree-en-vigueur-du-reglement-europeen-sur-lia-les-premieres-questions-reponses-de-la-cnil
- CNIL, dossier intelligence artificielle et recommandations : https://www.cnil.fr/fr/intelligence-artificielle
- Référentiel général d'amélioration de l'accessibilité (RGAA) : https://accessibilite.numerique.gouv.fr
- OWASP GenAI Security Project (Top 10 des risques LLM) : https://genai.owasp.org
- C2PA, standard de provenance des contenus générés : https://c2pa.org

- Normes ISO/IEC 27701 (système de management de la protection de la vie privée) et ISO/IEC 42001 (système de management de l'IA)

Données pour le POC

- Fashion Product Images (Kaggle) : https://www.kaggle.com/datasets/paramaggarwal/fashion-product-images-small